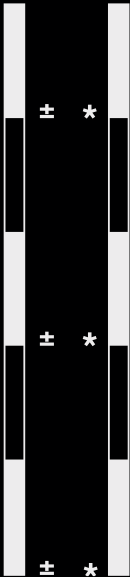


TENBIN:
SECURITY REVIEW
REPORT



Contents

1	Introduction	3
1.1	Products in Scope — Principles, Functions, and Review Focus	3
1.2	Engagement Outcome	4
2	About Verilog Solutions	5
3	Service Scope	6
3.1	Service Stages	6
3.2	Methodology	6
3.3	Audit Scope	6
3.4	Audit Objectives (from client scope)	7
3.5	Assumptions (from client scope)	7
3.6	Out of Scope	7
4	Project Summary	8
4.1	Roles and Trust	8
4.2	Architecture	8
4.3	Security Model (as designed)	8
5	Findings and Improvement Suggestions	9
5.1	High	9
5.2	Medium	12
5.3	Low	17
5.4	Informational	24
5.5	Positive Security Properties Observed	29
6	Appendix	30
6.1	Appendix I: Severity Categories	30
6.2	Appendix II: Status Categories	30
6.3	Appendix III: Client-Reported Commits Not in the Supplied Snapshot	30
6.4	Appendix IV: Negative Results	30
7	Disclaimer	32

1 | Introduction

This report presents Verilog Solutions' smart-contract security review for Tenbin Labs. The engagement covered two repositories: the Tenbin core contracts (new Morpho Vault V2 and Bebop integrations) and the Chainlink CCIP cross-chain adapter fork that adds Tenbin cooldown / unstake support.

The review was conducted from August 2026 through client remediation and follow-up. Preliminary findings were issued, remediations were reviewed across three client response rounds, and a fourth pass examined regressions introduced by those patches (in particular the L-04 deferred-outbound path). Final statuses in this report follow the latest client responses dated 31 August 2026. Where a cited fix commit was not present in the repositories supplied at report generation, that is noted under the finding.

Tenbin is an asset-token issuance platform. Each Tenbin asset is designed to track a real-world price (gold, BRL, MXN) by combining (i) off-chain futures that hold delta-one exposure to the underlying and (ii) on-chain USD-stablecoin collateral that earns low-risk yield. If on-chain yield covers off-chain funding costs, the token can remain pegged without each asset holding its own spot inventory. Live Ethereum mainnet tokens include `tGLD/stGLD`, `tBRL/stBRL`, and `tMXN/stMXN`.

1.1 | Products in Scope — Principles, Functions, and Review Focus

1.1.1 | StakedAsset (context for the adapter)

StakedAsset is the ERC-4626 vault that wraps a Tenbin asset (for example `tGLD` → `stGLD`). Deposit mints shares; exit is not always synchronous. When a cooldown period is configured, `withdraw/redeem` revert and users must `cooldownShares / cooldownAssets`, wait, then `unstake`. Underlying is escrowed in an **AssetSilo** for the duration. A restricted-account registry can freeze addresses for compliance.

What we examined. Whether a cross-chain wrapper that is the on-chain owner of every remote cooldown can still enforce restriction, pause, and ownership checks on the *origin user* rather than on the adapter itself; whether cooldown IDs are bound to a single remote identity; and whether a failed or paused exit can strand silo principal.

1.1.2 | GenericMorphoAdapter

This adapter connects a Morpho Vault V2 *parent* to a single ERC-4626 *child*. The parent allocates underlying into the adapter; the adapter deposits into the child and reports value back through one allocation ID. It exists because Morpho does not ship an audited generic ERC-4626 adapter; the code is a fork of `MorphoVaultV1Adapter` with the target set widened from MetaMorpho to “any standard ERC-4626.”

Functions. `allocate / deallocate` (slippage encoded in `data` as `minShares / maxShares`), `realAssets()` for parent NAV, factory `CREATE2` deploy, and an owner `rescueToken` that cannot pull the child share token.

Hazards reviewed. Fee-exclusive `convertToAssets` overstating exit value; donated shares counted at zero allocation (upstream ChainSecurity finding CS-MORPHO-VLT2-020); inflation/donation when the child has no virtual shares; a frozen `liquidityData` blob that cannot encode opposite min/max bounds; pairing with cooldown-gated (asynchronous) children such as **StakedAsset**; self-referential `parentVault == vault`; factory registry overwrite via a different `owner`.

1.1.3 | Gate

A Morpho Vault V2 gate that allows only a single `manager` to send or receive shares and assets. Used in Tenbin deploy scripts to restrict a parent vault to the collateral manager.

Hazards reviewed. Default or explicit `manager = address(0)`, which matches no real account and locks gated flows until the owner sets a non-zero manager.

1.1.4 | BebopHook

An adapter between Bebop's RFQ router and a Tenbin **Controller**. A mint or redeem is made to look like a Bebop swap, but output is sourced from Tenbin's primary market rather than market-maker inventory. The hook holds no order state: each fill completes atomically or reverts. Replay protection, expiry, and signer checks remain in the router and controller.

Functions. `bebopHook` (router-only), market-maker rotation, controller delegate flags, and owner token `rescue`.

Hazards reviewed. Signed quote rate vs floor rounding; fill/allowance mismatch on staked-asset redeem; leftover approvals; whether each controller signer must separately `setRecipientStatus` for the hook.

1.1.5 | TenbinCrossChainERC4626Adapter

A fork of Chainlink's CCIP ERC-4626 adapter. The pre-fork contract was previously audited by Chainlink; this review treats Tenbin's commit as a diff plus the residual custody design of failed-message recovery. The Tenbin fork binds a single immutable vault and asset, removes target allowlisting and flat adapter fees, and replaces the first payload word (legacy vault address) with packed `actionAndId`.

Intended actions.

- **DEPOSIT (0)** — CCIP delivers underlying; adapter calls `vault.deposit` and locally delivers or bridges shares.
- **COOLDOWN (1)** — CCIP delivers shares; adapter calls `cooldownShares`; Tenbin escrows underlying in the silo under the *adapter* as owner; adapter records `(sourceChain, id) → sender`. No token is returned in this step.
- **UNSTAKE (2)** — Tokenless message from the same chain and sender after cooldown expiry; adapter `unstake`s and delivers or bridges underlying.
- **CANCEL_COOLDOWN (3)** — Same authorization; reminds shares and delivers or bridges them.

Outbound CCIP on the return leg is paid from the adapter's shared native balance (`Router.getFee` in the adapter chain's native token). If that balance is insufficient, current remediations defer the send into `pendingOutbounds` for a later `completeDeferredOutbound`. Failed inbound processing that carried tokens is stored as `BASIC` and may be refunded cross-chain (`refundFailedMessage`, caller-funded) or recovered locally if a non-zero `localRefundAddress` was encoded.

Hazards reviewed. Permanent lock of delivered ERC-20s when `localRefundAddress` is zero and the return lane cannot send; silent `sendToken` success that marked refunds `RESOLVED` without moving tokens; permissionless dust returns draining the shared native reserve; pause flags that gate already-committed cooldowns; source-chain decommission without an escape hatch; legacy 128-byte payloads decoded as actions; zero beneficiaries on EVM and SVM; fail-open `bytes32(message.sender)` vs the file's own 32-byte conversion rail; frontend decimal and status-display issues (confirmed out of production use).

1.2 | Engagement Outcome

No critical-severity issues were identified in the original review. The highest residual concerns after remediation are (i) the acknowledged design that a misconstructured token-carrying message with a zero local refund address can still lock ERC-20s in a non-upgradeable adapter, and (ii) the acknowledged shared-reserve grief on mainnet return legs, which Tenbin mitigates operationally by monitoring and replenishing native balances rather than charging a return-leg asset fee. A High regression in `refundFailedMessage` introduced by the first L-04 patch was subsequently fixed.

2 | **About Verilog Solutions**

Founded by a group of cryptography researchers and smart contract engineers in North America, Verilog Solutions elevates the security standards for Web3 ecosystems by being a full-stack Web3 security firm covering smart contract security, consensus security, and operational security for Web3 projects.

Verilog Solutions team works closely with major ecosystems and Web3 projects and applies a quality above quantity approach with a continuous security model. Verilog Solutions onboards the best and most innovative projects and provides the best-in-class advisory services on security needs, including on-chain and off-chain components.

3 | Service Scope

3.1 | Service Stages

Our auditing service includes the following two stages:

- Pre-Audit Consulting Service
- Smart Contract Auditing Service

3.1.1 | Pre-Audit Consulting Service

As a part of the audit service, the Verilog Solutions team worked closely with the Tenbin Labs development team to discuss potential vulnerabilities and smart-contract development best practices in a timely fashion. Findings were exchanged promptly during the preliminary-report stage; remediations, acknowledgements, and follow-up regressions were reviewed through 31 August 2026.

3.1.2 | Smart Contract Auditing Service

The Verilog Solutions team analyzed the in-scope diff and the residual custody, adapter, and hook logic using a detail-oriented approach, and suggested improvements to the existing code. Details can be found under Findings and Improvement Suggestions.

3.2 | Methodology

■ Code Assessment

- We evaluate the overall quality of the code and comments as well as the architecture of the repositories.
- We help the project development team improve the overall quality of the repositories by providing suggestions on refactorization to follow the best practices of Web3 software engineering.

■ Code Logic Analysis

- We dive into the data structures and algorithms in the repositories and provide suggestions to improve correctness, access control, and fund-safety invariants.
- We analyze module hierarchy (CCIP adapter, Morpho adapter/factory/gate, Bebop hook) and integration with **StakedAsset**, Morpho Vault V2, Chainlink CCIP, and the Bebop router.

3.3 | Audit Scope

The client scope document (revision 1.1, 29 July 2026) specified approximately 569 lines of added logic across two repositories. Verilog reviewed those targets in the context of the surrounding custody and integration surfaces named below.

- **tenbin-contracts** — <https://github.com/tenbinlabs/tenbin-contracts>
src/external/morpho/GenericMorphoAdapter.sol, GenericMorphoAdapterFactory.sol, Gate.sol;
src/external/bebop/BebopHook.sol, IBebopHook.sol.
- **cross-chain-erc4626-vault** — <https://github.com/tenbinlabs/cross-chain-erc4626-vault>
Tenbin fork of Chainlink's CCIP ERC-4626 adapter (src/CrossChainERC4626Adapter.sol, later src/TenbinCrossChainERC4626Adapter.sol). In-scope as a diff versus the pre-fork adapter, plus failed-message recovery, outbound native-fee payment, and cooldown bookkeeping that the fork newly custodians.

3.3.1 | Commits Reviewed

Repo	Stage	Commit
tenbin-contracts	initial scope	633540ee51d7a069f4a5a53feccd8e3498d1ff14
cross-chain-erc4626-vault	initial scope	cde2faffec4470c9a3f33103efd6a52d027cd696
cross-chain-erc4626-vault	remediations / L-04 lock fix	c76305f5361de51216936b927edf509b7bebbd50
tenbin-contracts	workspace snapshot at report date	1ff7cec84dbd2e8ee9c38ad028bb9cb889772a2c

Client responses dated 31 August 2026 cite additional fix commits (including `be939bc`, `031df2d`, `00c8093`, `11c9102`, `3b57088`) that were not present in the two repositories supplied at report generation. Statuses for those items are recorded as client-reported; operators should confirm the deployed bytecode includes them.

3.3.2 | In-Scope Size (initial scope document)

Component	Approx. size
Cross-chain cooldown adapter (diff)	~149 added / 233 removed
BebopHook.sol	241 lines
IBebopHook.sol	20 lines
GenericMorphoAdapter.sol	129 lines
GenericMorphoAdapterFactory.sol	30 lines
Total (scope doc)	~569 lines added

OpenZeppelin, Morpho Vault V2, Chainlink CCIP, and Bebop router implementations are external dependencies. Test suites, deployment keys, and production frontend apps (except where they demonstrated a protocol issue) are out of scope.

3.4 | Audit Objectives (from client scope)

- Review the cross-chain cooldown commit versus the pre-fork adapter and validate it in the context of Chainlink CCIP.
- Ensure cross-chain operations do not result in stuck funds.
- Validate BebopHook in the context of the Bebop ecosystem.
- Review `GenericMorphoAdapter` for Morpho Vault V2 compatibility and minimal added risk, including use as an adapter that funds a standard ERC-4626 vault.

3.5 | Assumptions (from client scope)

- The pre-fork `CrossChainERC4626` adapter is secure to Chainlink's standards (prior Chainlink audit).
- `GenericMorphoAdapter` will be used with standard ERC-4626 vaults. The scope wording "non-synchronous ERC4626" was treated as a client determination (see H-02).

3.6 | Out of Scope

- Live deployment keys, multisig / operational security, and off-chain hedging / futures operations
- Full Tenbin core (`Controller`, `CollateralManager`, `AssetToken`, oracles) except as integration context for the in-scope adapters
- Production frontend (client confirmed in-repo UI is not intended for production; L-02 and I-03)
- Formal verification and economic modeling of the gold / FX peg

4 | Project Summary

Tenbin Labs issues liquid, yield-bearing commodity and FX tokens. On-chain collateral (USD stablecoins) is put to work in curated yield venues while an off-chain book maintains delta-one exposure to the referenced asset. The in-scope work extends that system in three directions: Morpho Vault V2 as a yield venue, Bebop RFQ as a primary-market mint/redeem rail, and Chainlink CCIP as a remote cooldown/unstake rail for `StakedAsset`.

4.1 | Roles and Trust

- **Remote user** — originates CCIP messages; does not hold the on-chain cooldown. The adapter is the `StakedAsset` owner.
- **Adapter admin** (`DEFAULT_ADMIN_ROLE`) — chain types, CCV / finality config, granting other roles, native recovery of ETH (not user ERC-20s). The adapter is not upgradeable; `ROUTER`, `VAULT`, and `ASSET` are immutable.
- **Adapter gatekeeper** (`GATEKEEPER_ROLE`) — `setProcessingEnabled` (deposit, redeem, cooldown, cancel). Added in M-03 (3d4f156) to match the pause role on `Controller` / `CollateralManager`. Not granted in the constructor; admin must assign it after deploy. Admin does not confer pause rights by itself.
- **Morpho curator / parent vault** — timelocked `addAdapter` / caps; chooses the ERC-4626 child.
- **Bebop market maker** — signs hook and controller orders; hook owner rotates the maker and delegates.

4.2 | Architecture

- **Morpho** — parent Vault V2 allocates through `GenericMorphoAdapter` into a child ERC-4626. Optional `Gate` limits the parent to one manager (`CollateralManager` in deploy scripts).
- **Bebop** — router calls `BebopHook`, which mints or redeems through `Controller`. Fill-or-kill; hook should not retain inventory.
- **CCIP adapter** — inbound `ccipReceive` hits `StakedAsset` / `AssetSilo`; optional return-leg `ccipSend` is paid from the adapter native reserve, or deferred / recovered if the send cannot complete.

4.3 | Security Model (as designed)

Cross-chain cooldowns are intentionally owned by the adapter. Authorization maps (`sourceChainSelector`, `cooldownId`) to a 32-byte sender. Pause switches are global and gated by `GATEKEEPER_ROLE`; chain configuration is gated by `DEFAULT_ADMIN_ROLE`. Failed token-carrying messages rely on a correctly encoded `localRefundAddress` and/or a working return lane; Tenbin's stated preference is that the protocol owner never unilaterally seizes user ERC-20s. Return-leg CCIP fees are subsidized from a shared native balance, replenished operationally rather than charged as a per-message asset fee.

5 | Findings and Improvement Suggestions

Severity	Total	Acknowledged	Partial	Resolved
Critical	0	0	0	0
High	3	2	0	1
Medium	5	1	1	3
Low	7	3	1	3
Informational	5	2	1	2

Findings below use the identifier scheme from the 18 August 2026 merged preliminary report. H-03 is the High regression discovered while reviewing the first L-04 patch. Statuses follow the 31 August 2026 client response unless noted.

5.1 | High

5.1.1 | H-01 — Failed CCIP Messages Can Permanently Lock Delivered ERC-20s

Severity	High
Source	TenbinCrossChainERC4626Adapter.sol
Status	Acknowledged

■ Description

The adapter is not upgradeable. When the CCIP router has already credited tokens and `processMessage` reverts, `ccipReceive` catches the error, may mark the message `BASIC`, and returns success to the router — CCIP will not redeliver. The only ERC-20 exits are `refundFailedMessage` (requires a working return lane) and `recoverFailedMessageLocally` (requires a non-zero encoded `localRefundAddress`). `recoverNative` moves ETH only. If `localRefundAddress` is zero (blank field, coerced address, or payload length $\neq 128$) and the return lane cannot send, delivered tokens remain in the adapter with no on-chain exit. A later adapter deploy cannot reach those balances.

■ Recommendation

Before deploy, require a non-zero `localRefundAddress` on every token-carrying send at the encoder, and/or add a scoped admin escrow that can move only that message's `destTokenAmounts`. Do not add a blanket `rescueERC20`.

■ Client Response

Acknowledged as a product preference: the owner should not control user funds; the message is assumed to be constructed as the user intends. Desired fallback is source-chain refund, then local refund address.

■ Status

Acknowledged. Residual is deploy-blocking if encoders can omit `localRefundAddress`. Verilog recommends encoder-side enforcement even if the contract is left unchanged.

5.1.2 | H-02 — Synchronous-Only Deallocation Locks Capital in a Cooldown or Asynchronous Child

Severity	High
Source	GenericMorphoAdapter.sol / StakedAsset.sol
Status	Acknowledged

■ Description

`deallocate` exits only through the child's synchronous `withdraw()`. On `StakedAsset` with `cooldownPeriod > 0`, `withdraw` reverts `RequiresCooldown`. Child shares are non-rescuable and vault is immutable. If this pairing is funded, allocator and permissionless `forceDeallocate` both revert. Severity depends on whether "standard, non-synchronous ERC4626" in the scope document is literal (High) or a typographical stand-in for synchronous vaults (Low).

■ Recommendation

Prohibit cooldown / ERC-7540 children in NatSpec and factory checks, or build a purpose-built async adapter.

■ Client Response

Acknowledged. Assumption is the adapter is only used with standard ERC-4626 vaults. NatSpec added (067cdc0).

■ Status

Acknowledged. Residual is an operator / curator admission error against `StakedAsset` or any cooldown-gated 4626.

5.1.3 | H-03 — L-04 Patch Marked Refunds RESOLVED Without Moving Tokens

Severity	High
Source	<code>refundFailedMessage</code> / <code>sendToken</code>
Status	Resolved
Introduced	First L-04 remediation (8af8f8c)

■ Description

The L-04 deferred-outbound patch made `sendToken` return silently when `address(this).balance < fee` instead of reverting. `refundFailedMessage` deleted the failed-message record and set **RESOLVED** *before* inspecting whether any tokens moved. With `msg.value = 0` and a low adapter balance, `totalPaidFee` stayed 0, the fee guard did not fire, and `MessageRefunded` was emitted. A second call reverted `MessageNotFailed`. The user's ERC-20s were then permanently stuck. The path is permissionless.

■ Recommendation

Require a success flag from every `sendToken` (or revert on insufficient native); only then mark **RESOLVED**.

■ Client Response

Fixed in c76305f: `sendToken` returns success; `refundFailedMessage` reverts unless the flag is true.

■ Status

Resolved. Verified on c76305f (`if (!success) revert InsufficientProvidedFee()`).

5.2 | Medium

5.2.1 | M-01 — Inbound Payload First Word Is `actionAndId`; Legacy Encoding Is Misread

Severity	Medium
Source	TenbinCrossChainERC4626Adapter.sol
Status	Acknowledged

■ Description

Both Tenbin and legacy payloads are 128 bytes. The first word is now `actionAndId`, not a vault address. A legacy encoder yields `uint8(address » 128)` as the action: values 0–3 run the wrong vault action; values > 3 revert `InvalidAction` and can strand tokens via H-01.

■ Recommendation

Change `typeAndVersion` and add a payload magic/version. Update every sender.

■ Client Response

`typeAndVersion` set to `TenbinCrossChainERC4626Adapter 1.0.0 (a5c83bc)`. No in-repo production UI; Chainlink recommended the version-string change. No payload discriminator added.

■ Status

Acknowledged. Residual if any external legacy encoder still targets this adapter.

5.2.2 | M-02 — Zero Beneficiary Passes Validation and Can Lose Bridged Funds

Severity	Medium
Source	TenbinCrossChainERC4626Adapter.sol
Status	Resolved

■ Description

EVM beneficiary packing originally accepted `bytes32(0)`. Local ERC-20 transfer to zero often reverts (message becomes `BASIC`); SVM `tokenReceiver` of zero can burn funds.

■ Recommendation

Reject zero on both families.

■ Client Response

Empty `bytes32` rejected (`e89a0fef`). SVM path follow-up 11c9102 (31 August).

■ Status

Resolved (client-reported for SVM). The supplied snapshot at `c76305f` rejects zero for EVM via `_requireValidEvmBeneficiary`; confirm 11c9102 is included before SVM production lanes.

5.2.3 | M-03 — Committed Cooldown Principal Is Gated on Entry-Side Switches, with No Escape Hatch

Severity	Medium
Source	TenbinCrossChainERC4626Adapter.sol
Status	Partially Resolved

■ Description

Remote cooldowns are owned by the adapter. Originally UNSTAKE shared `redeemsEnabled` with new cooldowns and `CANCEL_COOLDOWN` shared `depositsEnabled` with new deposits. Disabling ingress therefore froze in-flight silo principal. Disabling a source chain (`setChainType(NONE)`) or a permanently retired CCIP lane blocked the only party who could finish the cooldown. There was no hub-side unstake.

■ Recommendation

Split ingress/exit switches; add a beneficiary-pinned escape hatch that works for EVM and SVM and is not gated by the exit pause.

■ Client Response

Independent action switches, `GATEKEEPER_ROLE` for `setProcessingEnabled`, and `resolveDecommissionedCooldown` (3d4f156). Hatch is documented EVM-origin only. `preview()` still checks `redeemsEnabled` while cooldown execution uses `cooldownsEnabled`, left as-is because `preview` is deposit/redeem only.

■ Status

Partially Resolved. EVM users on a decommissioned chain can settle locally. SVM users, cross-chain smart-contract wallets, and pause-gated exits remain acknowledged residuals.

5.2.4 | M-04 — Fee-Exclusive Marking Permits Externalization of the Child's Exit Fee

Severity	Medium
Source	GenericMorphoAdapter.sol
Status	Resolved

■ Description

`realAssets()` used `convertToAssets` (fee-exclusive). Parent NAV overstated recoverable value by the child's exit fee. `forceDeallocate` is permissionless even with Gate installed; the inflated NAV also feeds Tenbin collateral accounting.

■ Recommendation

Value with `previewRedeem(balance)`; do not naively wrap the same helper for the zero-allocation guard (see M-05).

■ Client Response

`realAssets / _position` use `previewRedeem (267e13be)`.

■ Status

Resolved. Verified on `tenbin-contracts@1ff7cec`.

5.2.5 | M-05 — Donated Shares Count at Zero Allocation and Can Never Be Permissionlessly Removed

Severity	Medium
Source	GenericMorphoAdapter.sol
Status	Resolved

■ Description

Upstream short-circuits `realAssets` to zero when the parent holds no allocation. The fork removed that guard (ChainSecurity CS-MORPHO-VLT2-020). Anyone can donate child shares; Vault V2 sums them; `forceDeallocate` reverts at zero allocation. Absorption is throttled by `maxRate`.

■ Recommendation

Split `_position()` (unguarded) from `realAssets()` (zero if allocation is 0); use `_position` inside `allocate/deallocate`.

■ Client Response

Implemented (51cfcc3).

■ Status

Resolved. Verified on 1ff7cec.

5.3 | Low

5.3.1 | L-01 — Failed UNSTAKE / CANCEL_COOLDOWN Messages Stay Permanently Unresolved

Severity	Low
Source	TenbinCrossChainERC4626Adapter.sol
Status	Resolved

■ Description

Tokenless control messages that reverted were marked **BASIC** but had no refundable amounts, so records could never reach **RESOLVED**. No principal was locked; the original CCIP message cannot be re-executed.

■ Client Response

Catch block skips **BASIC** when no tokens were delivered (**fd3e5f13**). Users must pay for a new message if they sent a wrong cooldown id or unstaked too early — acknowledged UX.

■ Status

Resolved for bookkeeping. Residual retry-fee UX acknowledged.

5.3.2 | L-02 — Solana Path Always Assumes 9 Decimals (USDC Is 6)

Severity	Low
Source	Frontend <code>SendDialog.tsx</code> / <code>send.ts</code>
Status	Acknowledged

■ Description

Solana sources fell back to 9 decimals. USDC on Solana has 6; a user typing 1 could bridge 1000× the intended amount.

■ Client Response

In-repo UI is not production; Tenbin will not use it. Chainlink confirmed the UI is a test tool.

■ Status

Acknowledged / out of production scope.

5.3.3 | L-03 — A Single Static liquidityData Blob Cannot Serve Both Allocation Directions

Severity	Low
Source	GenericMorphoAdapter.sol
Status	Resolved

■ Description

`data` is `minShares` on allocate and `maxShares` on deallocate. Vault V2 liquidity adapters freeze one blob for both automatic directions. Follow-up: treating 0 as “skip slippage” skipped the entire `deposit/withdraw` when `assets > 0`, leaving allocations inconsistent.

■ Client Response

Zero skips the slippage check only (8d3db281); skip-entire-operation regression fixed in be939bc (31 August).

■ Status

Resolved (client-reported). The snapshot at 1ff7cec still gates `vault.deposit/withdraw` on `minShares > 0 / maxShares > 0`. Confirm be939bc (or equivalent) before using the adapter as a Vault V2 liquidity adapter.

5.3.4 | L-04 — Permissionless Dust Returns Can Exhaust the Shared Native CCIP Reserve

Severity	Low
Source	TenbinCrossChainERC4626Adapter.sol
Status	Partially Resolved

■ Description

Return-leg `ccipSend` is paid from `address(this).balance`. Any remote account can initiate minimum-size return-to-source transfers, each consuming a full outbound `getFee` on the *adapter* chain. On Ethereum this is material; inbound fees are paid on the (possibly cheap) source. Empty reserve stalls outbound messaging. Combined with M-03, a cooldown started while the reserve was healthy can be economically frozen. The first patch deferred outbound sends and, until H-03, broke `refundFailedMessage`. Remaining issues: dust can still drain the subsidy; deferred transfers need a completion path; local recovery of pending outbounds was incomplete in the first patch.

■ Recommendation

Charge a return-leg asset fee $\geq$ current outbound `getFee` (plus buffer), or require the user/relayer to pay native like `refundFailedMessage`. Keep a reserved native floor for committed UNSTAKE/CANCEL. Monitoring alone does not change the incentive.

■ Client Response

Deferred outbound + monitoring/replenish (8af8f8c, then H-03 fix c76305f). Dust drain acknowledged: small amounts can be legitimate, so no minimum size, to preserve UX.

■ Status

Partially Resolved. Availability grief on a mainnet adapter remains an accepted operational residual. Impact is much smaller if the adapter and return lanes are cheap-gas chains only.

5.3.5 | L-05 — Inflation-Resistance Requirement Removed While the Target Set Was Widened

Severity	Low
Source	GenericMorphoAdapter.sol
Status	Acknowledged

■ Description

Upstream required inflation-resistant Morpho Vaults V1 (initial deposit / virtual shares). The fork targets “any standard ERC4626.” `allocate` has no `shares == 0` invariant; `minShares` is the only protection and is attacker-chosen on the automatic liquidity path.

■ Client Response

Admission is the deployer’s and vault owner’s responsibility; Vault V2 timelock gives time to review. NatSpec restored (69caa76).

■ Status

Acknowledged.

5.3.6 | L-06 — Staked-Asset Redeem Passes Validation but Can Never Execute

Severity	Low
Source	BebopHook.sol
Status	Acknowledged

■ Description

A staked-asset redemption can pass `verifyHookData` and then revert in execution (allowance / units). No funds are lost; a signed order is wasted.

■ Client Response

Left as-is for gas. Hook users must not redeem staked assets. NatSpec documents the restriction.

■ Status

Acknowledged.

5.3.7 | L-07 — Caller-Chosen Owner Defeats the Write-Once Registry Guarantee

Severity	Low
Source	GenericMorphoAdapterFactory.sol
Status	Resolved

■ Description

CREATE2 address depends on (parent, vault, owner); the registry is genericMorphoAdapter[parent][vault]. A different owner overwrites the lookup. Self-referential parentVault == vault was a related constructor gap.

■ Client Response

Constructor rejects self-referential vaults (b5a6bc92). Registry uniqueness follow-up 031df2d (31 August).

■ Status

Resolved (client-reported for registry uniqueness). Snapshot at 1ff7cec still assigns genericMorphoAdapter[parent] without a prior-set revert. Confirm 031df2d before treating the registry as canonical.

5.4 | Informational

5.4.1 | I-01 — Gate Manager Can Be address(0), Which Locks the Vault

Severity	Informational
Source	Gate.sol
Status	Resolved

■ Description

`setManager` allowed zero; default storage is zero until set.

■ Client Response

Revert on zero (cb36964).

■ Status

Resolved. Verified on 1ff7cec.

5.4.2 | I-02 — Unused Fee Roles and Outdated Docs Left After the Tenbin Fork

Severity	Informational
Source	Adapter / docs / frontend
Status	Partially Resolved

■ Description

Flat fees were removed but `FEE_*` role constants and NatSpec / operator docs still described them.

■ Client Response

Unused variables deleted (`4ce82c1`); NatSpec cleanup `3b57088`. Frontend will remain untouched; docs via PR `#4`.

■ Status

Partially Resolved. Code constants removed; leftover UI/docs acknowledged.

5.4.3 | I-03 — UI Shows Success When the Vault Action Actually Failed

Severity	Informational
Source	Adapter / <code>TrackedMessages.tsx</code>
Status	Acknowledged

■ Description

`ccipReceive` returns success to the OffRamp on a caught `processMessage` failure. Monitors that treat CCIP SUCCESS as vault success mislead users (especially with H-01).

■ Client Response

In-repo UI is not production.

■ Status

Acknowledged.

5.4.4 | I-04 — Fail-Open Cooldown Authorization Bypasses the File's Own Conversion Rail

Severity	Informational
Source	TenbinCrossChainERC4626Adapter.sol
Status	Resolved

■ Description

Refund paths used `_normalizeToBytes32` (exactly 32 bytes). Cooldown auth used `bytes32(message.sender)`, which pads/truncates. `bytes32(0)` is also the mapping default. Safe for current EVM/SVM 32-byte senders; fail-open if a third family is added.

■ Client Response

Normalize once and reuse (39f8c98). Explicit `owner != bytes32(0)` in 00c8093 (31 August).

■ Status

Resolved (client-reported for the zero-owner guard). Normalization is verified on c76305f.

5.4.5 | I-05 — Each Order Signer Must Separately Call `setRecipientStatus`

Severity	Informational
Source	BebopHook / Controller operations
Status	Acknowledged

■ **Description**

A newly rotated controller signer cannot transact through the hook until it personally authorizes the hook as recipient. Silent operational outage.

■ **Client Response**

Documented as part of the market-maker rotation procedure; no additional preflight tests.

■ **Status**

Acknowledged.

5.5 | Positive Security Properties Observed

- Atomic try `this.processMessage`: vault mutations roll back if post-processing reverts.
- Cooldown completion bound to source chain and sender; restriction check added on adapter-mediated UNSTAKE.
- Failed token-carrying messages retain a dedicated refund record; caller-funded `refundFailedMessage` does not spend the shared reserve as the sole path.
- Morpho `realAssets` is fee-aware and ignores unallocated donations in the remediated design.
- Bebop hook is fill-or-kill with exact router allowance and no retained order state.

6 | Appendix

6.1 | Appendix I: Severity Categories

Severity	Description
Critical	Issues that enable direct fund loss or permanent lock without realistic admin recovery under expected usage. All critical severity issues should be resolved.
High	Issues that are highly exploitable security vulnerabilities. It may cause direct loss of funds / permanent freezing of funds. All high severity issues should be resolved.
Medium	Issues that are only exploitable under some conditions or with some privileged access to the system. Users' yields/rewards/information is at risk. All medium severity issues should be resolved unless there is a clear reason not to.
Low	Issues that are low risk. Not fixing those issues will not result in the failure of the system. A fix on low severity issues is recommended but subject to the clients' decisions.
Informational	Issues that pose no risk to the system and are related to the security best practices. Not fixing those issues will not result in the failure of the system. A fix on informational issues or adoption of those security best practices-related suggestions is recommended but subject to clients' decision.

6.2 | Appendix II: Status Categories

Status	Description
Unresolved	The issue is not acknowledged and not resolved.
Partially Resolved	The issue has been partially resolved.
Acknowledged	The finding / suggestion is acknowledged but not fixed / not implemented.
Resolved	The issue has been sufficiently resolved.

6.3 | Appendix III: Client-Reported Commits Not in the Supplied Snapshot

Commit	Finding	Note
be939bc	L-03	Client: skip-slippage-only. Not in supplied <code>tenbin-contracts@1ff7cec</code> .
031df2d	L-07	Client: registry uniqueness. Factory in snapshot still keys (<code>parent</code> , <code>vault</code>) only.
00c8093	I-04	Client: reject zero cooldown owner.
11c9102	M-02	Client: SVM zero-beneficiary check.
3b57088	I-02	Client: NatSpec cleanup; frontend left untouched.

6.4 | Appendix IV: Negative Results

The following paths were examined and did not yield standalone findings, or were confirmed as intended behavior:

- Theft of another user's cooldown via CCIP — `cooldownAccounts` binds sender; `onlyRouter`; `processMessage` is atomic.
- Half-committed unstake plus failed bridge — `try this.processMessage` rolls back vault state.
- Unauthorized drain of custodian / silo / Morpho parent — role and `parentVault` gated.

- Permissionless **refundFailedMessage** sending tokens to the caller — tokens return to the original sender by construction.

7 | Disclaimer

Verilog Solutions receives compensation from one or more clients for performing the smart contract and auditing analysis contained in these reports. The report created is solely for Clients and published with their consent. As such, the scope of our audit is limited to a review of code, and only the code we note as being within the scope of our audit is detailed in this report. It is important to note that the Solidity code itself presents unique and unquantifiable risks since the Solidity language itself remains under current development and is subject to unknown risks and flaws. Our sole goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies. Thus, Verilog Solutions in no way claims any guarantee of security or functionality of the technology we agree to analyze.

In addition, Verilog Solutions reports do not provide any indication of the technology's proprietors, business, business model, or legal compliance. As such, reports do not provide investment advice and should not be used to make decisions about investment or involvement with any particular project. Verilog Solutions has the right to distribute the Report through other means, including via Verilog Solutions publications and other distributions. Verilog Solutions makes the reports available to parties other than the Clients (i.e., "third parties") – on its website in hopes that it can help the blockchain ecosystem develop technical best practices in this rapidly evolving area of innovation.